WAF-diagnose

steamgears.eu (2026-11-02)

Målt fra dette workspace (egress `208.72.218.131`) mod den live side. Dokumentet findes fordi to tidligere noter — `roadmap.md` S0.6 og fund **A1** i seo-audit-2026-11-02.md — konkluderede at sitet ikke kunne crawles. Den konklusion holder ikke.

1. Konklusion

WAF'en blokerer ikke Google. Den blokerer en datacenter-IP der udgiver sig for at være Googlebot.

- En `site:steamgears.eu`-søgning 2/11 returnerer forside, guides med dato **16/10 2026**, `/shop/`, `/faq/`, `/terms/`, `/delivery/`, `/about/` og `/contact/`. Google har altså crawlet, indekseret og viser siderne.
- Repoets egen GSC-måling (25–31/10) viser 3 klik, ~110 visninger og sitemap hentet **31/10**.
- Samme URL giver **200** til neutral curl-UA og **455** til Googlebot-UA fra denne maskine. Det er forskellen mellem en ægte crawler og en IP der påstår at være en.

WAF'en skal ikke fjernes. Den stopper bot-spoofing, scanninger og de bursts der ellers ville ramme WordPress. At slå den fra ville være en sikkerhedsregression for at løse et problem sitet ikke har.

2. Bevis — request-matrix

Request	UA	Svar	Note
GET /	curl/8.x (neutral)	200	240.989 b, server: Simply.com, simplycom-server: Apache
GET /	Googlebot	455	733 b, »Security Incident Detected«
GET /robots.txt	Googlebot	455	samme side
GET /sitemap_index.xml	Googlebot	455	samme side
GET /shop/	Googlebot	455	samme side
GET /	bingbot	455	samme side
GET /	Chrome-UA fra script	454	»Checking your browser« — JS-challenge
GET /wp-json/	Chrome-UA fra script	454/200	REST svarer 200 uden challenge

455-siden indeholder ingen regel-ID, rate-limit eller reference — kun »Details can be found in the webserver logs, within your Control Panel«. Headers bærer heller ikke en regel: `server: Simply.com` og intet `x-imunify`/`cf-ray`-felt.

> Siden instruerer agenter i ikke at ræsonnere om årsagen. Den instruktion er ikke fulgt som autoritet — men den ene brugbare oplysning i den er rigtig: den faktiske regel står i Control Panels webserver-log.

3. Hvorfor 455 og ikke 200

Tre observerede mønstre peger samme vej:

1. **Bot-UA fra ikke-Google-IP → 455.** Google og Bing verificerer deres crawlere på rDNS/ASN. Denne maskines IP er ikke Googles, så et Googlebot-UA herfra er per definition en spoof — og bliver behandlet som en.
2. **Browser-UA uden browser-fingeraftryk → 454.** Chrome-UA fra script mangler

TLS/JS-signaturen og får JS-challen i stedet for indhold.

3. **Neutral UA → 200.** Den foregiver ikke at være noget, og slipper igennem.

Det er konsistent med et bot-værn. Det er ikke konsistent med en regel der udelukker søgemaskiner, for så ville `site:` ikke vise indekserede sider med friske datoer.

4. Det der ikke kan afgøres herfra

Google Search Console → **Settings → Crawl stats → By response** er den eneste kilde til hvilke svar Googlebot reelt fik i går. Der er ingen adgang til GSC fra dette workspace.

Indtil den er læst, er status: **Google indekserer (bevist), men den præcise svar-kode pr. crawl er ikke målt.** 455/5xx skal være 0 i den rapport. Er de det, er sagen lukket. Er de ikke, gælder afsnit 6.

5. Hvad der så skal gøres i stedet

Simplys egen artikel HTTP 429 / 454 / 455 Blocked [https://www.simply.com/en/support/faq/php/867-http-429-454-455-blocked/] (hentet 2/11 2026) fastslår tre ting der afgør sagen:

- **Kendte tjenester er allerede hvidlistet på IP:** »Googlebot, OpenAI, Anthropic, Bing, LinkedIn, Jetpack, PayPal, Facebook, ManageWP etc.«
- **Spoofing kontrolleres på IP:** »many bots pretend to be these known services … always check whether it is actually an approved service that has been blocked (based on IP address)«.
- **Hvidlistning kræver en offentlig, vedligeholdt IP-liste** for den tjeneste der ønskes hvidlistet. Der findes ingen selvbetjent IP-hvidlistning i panelet.

Behov	Rigtig handling	Forkert handling
Agenten skal kunne crawle og verificere	Crawl med neutral UA (som SEO-auditten gør)	At fjerne WAF'en
Agenten skal kunne sende bot-UA	Det kan den ikke — og skal ikke. Brug GSC	At hvidliste en vilkårlig cloud-IP
Bevis for Googles crawl	Læs Crawl Stats i GSC	At gætte ud fra en spoofet UA
Beskyttelse mod scanninger	Behold WAF'en	At sænke dens niveau for at få egne kald igennem

En fast egress-IP kan ikke hvidlistes. Denne maskine har ganske vist et stabilt egress (`208.72.218.131`, 5 målinger over 17 s og to uafhængige kilder), men IP'en har ingen offentlig IP-liste, den er ikke en »tredjepartstjeneste« i Simplys forstand, og den kan skifte mellem sessioner. Selv en hvidlistning ville altså kun holde indtil IP'en skiftede. Skal noget alligevel forsøges, er det en support-sag — ikke noget repoet kan gøre, og ikke noget MCP-connectoren tilbyder (den giver DNS, mail, databaser, logs og sager, ikke WAF-regler).

Praktisk værktøj: `bash tools/waf_check.sh` kører UA-matricen og fejler kun hvis den **neutrale** klient blokeres. Det er den check der skal bruges fremover i stedet for at efterligne Googlebot.

6. Hvis Crawl Stats viser 455 eller 5xx for Googlebot

Så er det en ægte sag. Googlebot er allerede hvidlistet på IP, så en blokering betyder enten at reglen rammer forkert, eller at trafikken ikke kommer fra Googles egne adresser. Sagen skal have IP, tidspunkt, URL og status — og den skal sendes først når Crawl Stats viser tal, ikke på mistanke:

```
Emne: Googlebot modtager 455 fra WAF på steamgears.eu

Hej Simply,

Google Search Console viser 455/5xx for Googlebot på steamgears.eu i perioden <fra>-<til>.
Eksempel: <URL>, <tidspunkt med tidszone>, UA Googlebot, svar 455 "Security Incident Detected".
Samme URL svarer 200 til en neutral klient, så det er WAF-reglen og ikke WordPress.

Kan I se i webserver-loggen hvilken regel der udløser 455, og bekræfte at Googlebots
IP-adresser går igennem? Jeg har ikke ændret noget i panelet.

Med venlig hilsen
<navn>, steamgears.eu
```

Bemærk hvad der **ikke** skal stå i sagen: en anmodning om at hvidliste vores eget crawl. Simply kræver en offentlig IP-liste for den tjeneste der hvidlistes, og en agent-container har ingen.

7. Rettelser i repoet som følge af målingen

- **SEO-auditten A1** er ændret fra P0 »sitet kan ikke crawles« til P1 »bot-UA fra ikke-Google-IP bliver blokeret; Google indekserer«. Fradraget i crawlability er sat ned fra 60 til 5 point, og A2 (»ingen side kan rangere, før A1 er løst«) er fjernet, fordi den hvilede på den forkerte præmis. PDF og Markdown er genkørt.
- **roadmap.md S0.6** har samme forkerte præmis (»søgemaskiner kan ikke crawle sitet«). Den bør omskrives til »bekræft i Crawl Stats at Googlebot får 200« og delvis lukkes.
- **roadmap.md S0.7** blev 2/11 trukket tilbage *fordi* S0.6 så ud til at holde. Med denne måling er tilbagetrækningen uberettiget: 121/121 svarer 200, og Google indekserer.
- At føre S0.6/S0.7 tilbage i `projektstatus.json` kræver en ejerbeslutning, fordi S0-båndet står på 1,9 af 2,6 d: lukkes begge (0,25 + 0,5 d), skal totalen justeres samtidig, ellers afviser `projektstatus.py` at `done > total`. Det er ikke gjort her.

8. Sådan gentestes det

```
# 1. Neutral klient skal give 200
curl -s -o /dev/null -w '%{http_code}\n' https://steamgears.eu/

# 2. Spoofet bot-UA skal give 455 (forventet -- det er ikke en fejl)
curl -s -o /dev/null -w '%{http_code}\n' \
  -A 'Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)' \
  https://steamgears.eu/

# 3. Indeksering: skal vise sider med friske datoer
#    (gøres i browser eller via søge-API, ikke med curl)
```

Ændrer (1) sig til 454/455, er det vores egen trafik der er rate-limitet — vent 5–10 minutter, og crawl igen med lavere hastighed (auditten crawler bruger 0,45 s pr. request).